המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____

מס' חדר:_____ מס' נבחן:_____

<u>בחינה בקורס:</u> מבוא לאבטחת סייבר

<u>קוד קורס:</u> מבחן לדוגמא

מרצה: ד"ר מנחם ליבוביץ

משך הבחינה: 01:30 שעות

<u>הוראות לנבחן:</u>

- **בבחינה חלק אחד:**

10 שאלות ברירה (סה"כ בחלק זה 100 נקודות)

א. יש להשיב על כל השאלות

ב. משקל כל שאלה 10 נקודות

ג. יש לבחור את התשובה <u>הנכונה ביותר</u> ולסמנה בדף הקידוד **<u>בעט שחור/כחול בלבד באופן ברור ומודגש</u>**

ד. **רק דף הקידוד ייבדק**

ה. ***** חשוב מאוד:**

בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)

יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: לא
- מחברת טיוטה: לא
- אין לסמן על דף הקידוד ו/או שאלון הבחינה בַּמַּדְגֵּשׁ (מַרְקֶר) זוהר
- יש להחזיר את טופס השאלון

בהצלחה!!!

שאלות ברירה - 100 נקודות

בחלק זה 10 שאלות. משקל כל שאלה 10 נקודות. יש להשיב על כל השאלות. יש לסמן את התשובה הנכונה ביותר, בעט שחור או כחול בלבד באופן ברור ועל פי ההנחיות, **בדף הקידוד המצורף בלבד**.

1. אליס ובוב רוצים לדבר ביניהם בצורה מוצפנת ומאובטחת כך שחווה לא תוכל לדעת מה תוכן ההודעות שהם שולחים אחד לשניה. הדרך היחידה של אליס ובוב לתקשר הוא דרך ערוץ התקשורת שביניהם.
נתון שלחווה יש יכולות האזנה, כלומר היא יכולה לראות הודעה הנשלחת בין אליס לבוב אך אין לה יכולות אחרות, בפרט, לחווה אין יכולות MitM והיא אינה יכולה לשלוח הודעות לאליס/בוב כלל - גם לא לשלוח הודעות משוכפלות מאליס/בוב.
מוצעות להלן מספר הצעות לקיום התקשורת בין אליס לבוב כך שהתקשורת תהיה מאובטחת.
איזו שיטה <u>לא</u> תעבוד?

א. אליס ובוב יתקשרו באמצעות הצפנה א-סימטרית. כל אחד מהם שולח לשני דרך הערוץ את המפתח הפומבי שלו ומאותו הרגע אליס שולחת לבוב את ההודעות שלה מוצפנות בעזרת המפתח הפומבי שלה (בוב אותו דבר, שולח הודעות שמוצפנות בעזרת המפתח הפומבי שלו).
ב. אליס ובוב יתקשרו באמצעות הצפנה סימטרית. הם מקיימים ביניהם החלפת מפתחות מבוססת דיפי-הלמן ומאותו הרגע כל ההודעות מוצפנות בהתאם.
ג. אליס ובוב יתקשרו באמצעות הצפנה סימטרית. הם ישלחו כל אחד לשני את התעודה שCA שכולם סומכים עליו הנפיק לכל אחד מהם, ואז יריצו את אלגוריתם דיפי-הלמן (וישתמשו בתעודות לאבטחת התהליך) ומאותו הרגע כל ההודעות מוצפנות בהתאם.
ד. אליס ובוב יתקשרו לסירוגין באמצעות הצפנה סימטרית והצפנה א-סימטרית. כאשר הם מתקשרים בהצפנה סימטרית הם מקיימים ביניהם החלפת מפתחות מבוססת דיפי-הלמן ומאותו הרגע כל ההודעות מוצפנות בהתאם. כאשר הם מתקשרים באמצעות הצפנה א-סימטרית הם ישלחו כל אחד לשני את התעודה שCA שכולם סומכים עליו הנפיק להם ומאותו הרגע כל ההודעות מוצפנות בהתאם (כמו שמצפינים ומפענחים בהצפנת מפתח פומבי רגילה).

2. איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. אליס בנתה אתר בית שרץ על foo.com בכתובת: http://foo.com/~alice ונתנה גישה לאתר הבית שלה לכל חבריה. לבוב, שאינו חבר של אליס, יש אתר בית משלו על foo.com בכתובת: http://foo.com/~bob. בוב החליט שכאשר ויקי, אחת מחברותיה של אליס, תגלוש לאתר הבית שלו, הוא ישים באתר הבית שלו iframe עם כתובת האתר של אליס ויקרא ממנו את התוכן של אתר הבית של אליס באמצעות javascript. כאשר בוב ינסה זאת, הוא יגלה, לצערו, שמנגנון ה same origin policy ימנע מהסקריפט שלו גישה למידע החוזר מאתר הבית של אליס.

ב. ניצול חולשת SQL injection כדי לבצע התקפת XSS הינו תרחיש הגיוני.

ג. אתר מסויים השתמש בחיטוי קלט כדי למנוע התקפות SQL injections. האתר הסיר את התווים: '=- (כל אחד בנפרד) מהקלטים של המשתמשים. למרבה הצער, הם שכחו את התו ; וזה מה שגרם להתקפת sql injection כנגד האתר. זאת דוגמא קלאסית לחסרון של שיטת blacklisting.

ד. בהתקפות stored XSS ו reflected XSS, הקוד הזדוני מוחזר כחלק מהתשובה של השרת

3. איזו מבין הטענות הבאות נכונה?

א. miner שמתחזק את כל הבלוקצ'יין באופן שוטף, יכול לעקוב אחר טרנזקציות ולדעת כמה ביטקוין יש לכתובת ביטקוין מסויימת ברגע נתון

ב. כדי לבזבז ביטקוין אין צורך במפתח הפרטי של הארנק הרלוונטי

ג. ביצוע שינויים במטבע הביטקוין מחייב אישור של סטושי

ד. ב micro payments, אליס חייבת לסמוך על בוב (ספק השירות) שישחרר לה את הכסף המגיע לה

4. איזו מבין הטענות הבאות נכונה?

א. הכח של ההמונים, למשל באמצעות botnet, הוא הכח המניע מאחורי התקפת DDoS

ב. התקפת קמינסקי היא בראש ובראשונה התקפת DoS

ג. התקפות DoS נעשות אך ורק בשכבה הפיזית, הלינק, התעבורה, והרשת

ד. ראשי התיבות DoS הן של התקפות Disk on Stack

5. היכן ביטקוין משתמש ב nonce?

א. בתהליך החיפוש אחר בלוק חדש (הבלוק הבא שיצטרף לבלוקצ'יין)

ב. כאשר miner מצטרף אל הרשת

ג. ב hard fork

ד. ב soft fork

6. איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. הגדרה נכונה של IDS מונעת התקפות DNS poisoning

ב. תוקף בעל יכולות eavesdropping בין קורבן לשרת ה DNS שאליו פנה לא תמיד יצליח בהתקפת DNS poisoning

ג. תוקף בעל יכולות MitM בין קורבן לשרת ה DNS שאליו פנה אינו צריך לנחש את ה transaction Id כדי להצליח בהתקפת DNS poisoning

ד. פרדוקס יום ההולדת אינו עקרון ייעודי עבור התקפת הרעלת ה DNS של קמינסקי, והוא עקרון שעומד בפני עצמו ושימושי גם לדברים אחרים.

7. איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. מניעת התקפות הרעלת ARP משמעותה הפסקה גורפת בשימוש בכתובות MAC

ב. תוקף MitM עלול לנסות לבצע התקפת degradation כנגד הקמת חיבור SSL/TLS

ג. התקפת degradation כנגד switch מבוצעת ע"י תוקפים הרוצים לקבל יכולות האזנה ברשת

ד. התקפת ARP poisoning עובדת כי בפרוטוקול ARP אין שימוש באימות ההודעות

8. איזו מבין הטענות הבאות נכונה?

א. ב syn-flood תוקף יעדיף כתובת IP מזוייפות כ source ובעיקר כאלו שלא יענו, כדי, בין השאר, למנוע החזרת RST על ה syn+ack ולמנוע חסימה של ההתקפה ע"י חסימת כתובות ספציפיות

ב. לא ניתן למנוע התקפות שנמוך כנגד switch

ג. על מנת לבצע ARP poisoning, התוקף זקוק ליכולת MITM

ד. שימוש ב syn-cookies מכריח את השרת לשמור אצלו בזיכרון את כל ה TCB החל מקבלת ה syn הראשוני

9. בפרוטוקול TLS, ה pre master secret מוצפן באמצעות?

א. המפתח הציבורי של השרת

ב. המפתח הסימטרי של ה CA

ג. המפתח הציבורי של הלקוח

ד. המפתח הפרטי של הלקוח

10. איזו מבין הטענות הבאות נכונה בהקשר של חתימה דיגיטלית?

א. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפרטי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפומבי של החותם והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ב. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפרטי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפרטי של החותם והשוואתו לתוצאת ביצוע hash על המידע שנשלח.

ג. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפומבי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י ביצוע hash על ה hash המוצפן שהתקבל והשוואתו למידע שנשלח.

ד. מחשבים את ה hash של המידע שרוצים לחתום עליו. מצפינים את ה hash עם המפתח הפומבי של השולח, ושולחים את הhash המוצפן והמידע עצמו. האימות מתבצע על ידי המקבל ע"י פענוח ה hash המוצפן בעזרת המפתח הפרטי של החותם והשוואתו לתוצאת ביצוע hash על המידע שנשלח.